

Escalada de privilegios

Contexto CyberCorp: El atacante ya está dentro del sistema con una cuenta normal (`usuarioprueba`). Ahora quiere convertirse en **Administrador** para tener control total.

¿Qué es escalada de privilegios?

En una empresa real significa:

```
Usuario normal → Administrador  
Sin acceso → Acceso total  
No puede instalar → Puede instalar cualquier cosa
```

Es una de las técnicas más buscadas en entrevistas SOC.

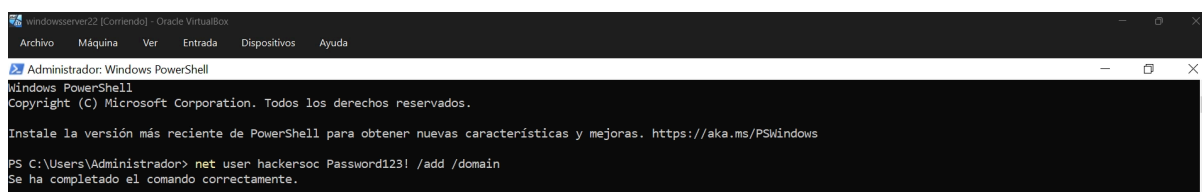
MISIÓN 1 — Simular el ataque en Windows Server

Abre **PowerShell** como **Administrador** en Windows Server.

PASO 1 — Crea un usuario sospechoso

powershell

```
net user hackersoc Password123! /add /domain
```



PASO 2 — Agrégalo al grupo Administradores

powershell

```
net localgroup Administradores hackersoc /add
```

```

Instale la versión más reciente de PowerShell para obtener nuevas características y mejoras. https://aka.ms/PSWindows

PS C:\Users\Administrador> net user hackersoc Password123! /add /domain
Se ha completado el comando correctamente.

PS C:\Users\Administrador> net localgroup Administradores hackersoc /add
Se ha completado el comando correctamente.

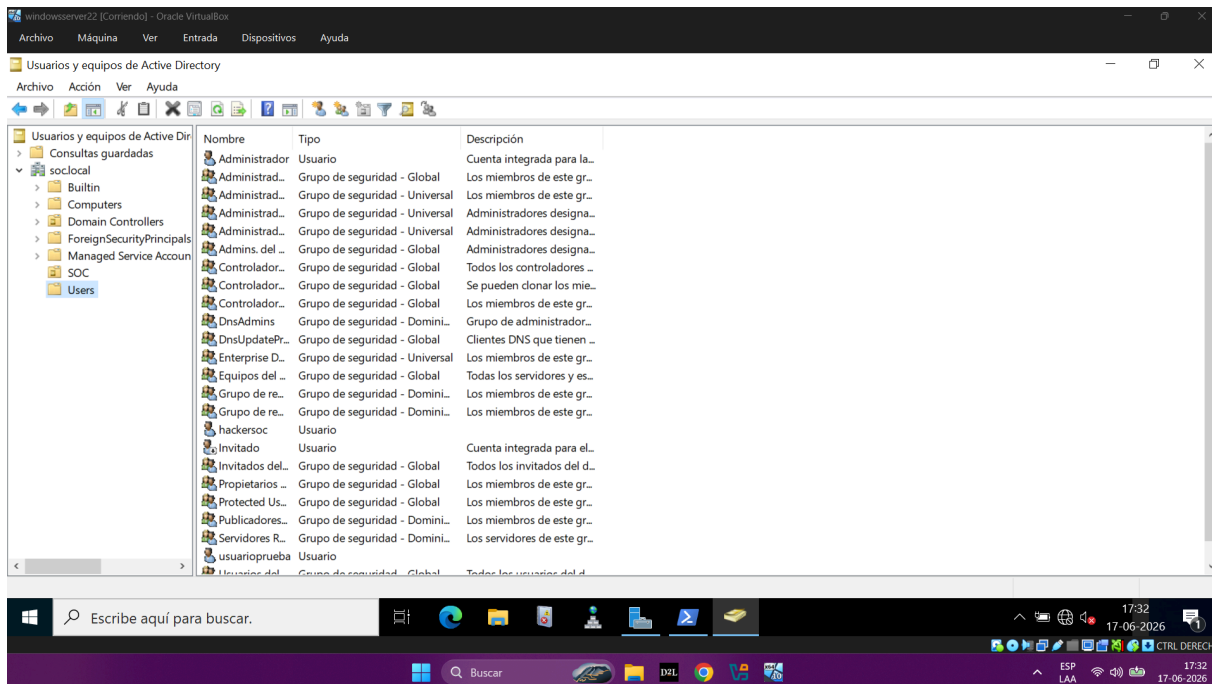
```

También agrégalo a grupos privilegiados de dominio:

powershell

```
net group "Domain Admins" hackersoc /add /domain
```

Como el comando no funcionó correctamente, realicé el procedimiento de forma manual. Accedí a **Users**, seleccioné **Nuevo** → **Grupo**, creé el grupo llamado **Domain Admins** y posteriormente agregué al usuario **hackersoc** como miembro del grupo.

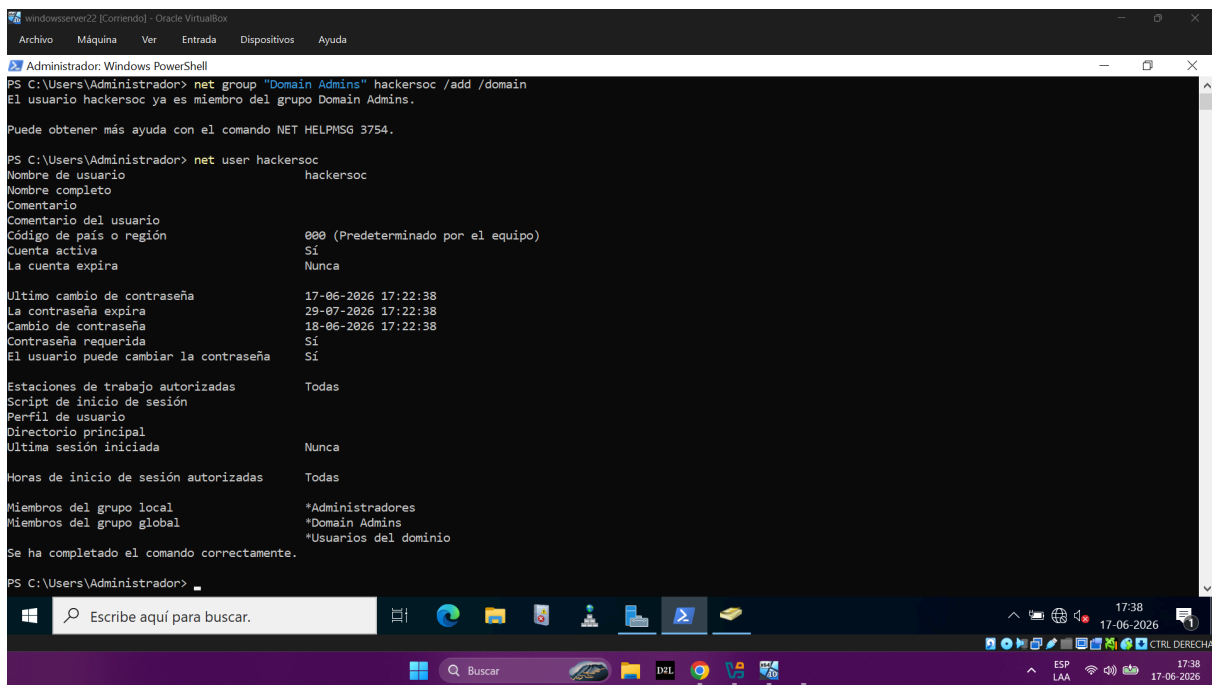


PASO 3 — Verifica que quedó en el grupo

powershell

```
net user hackersoc
net localgroup Administradores
```

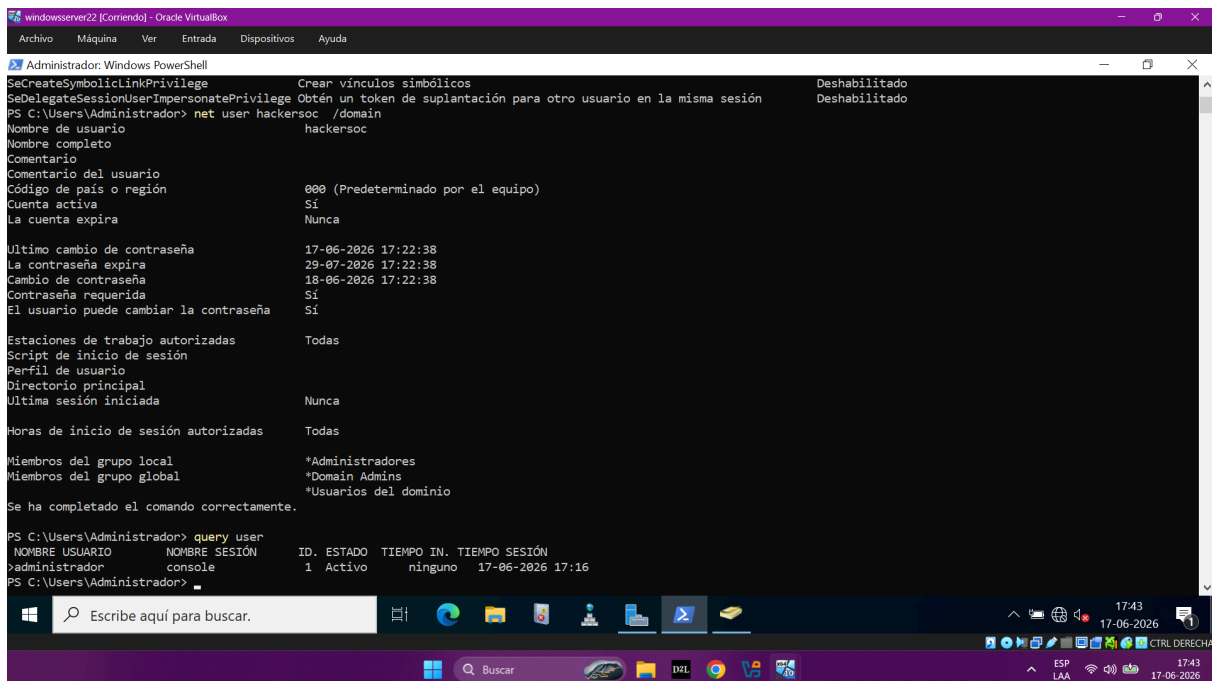
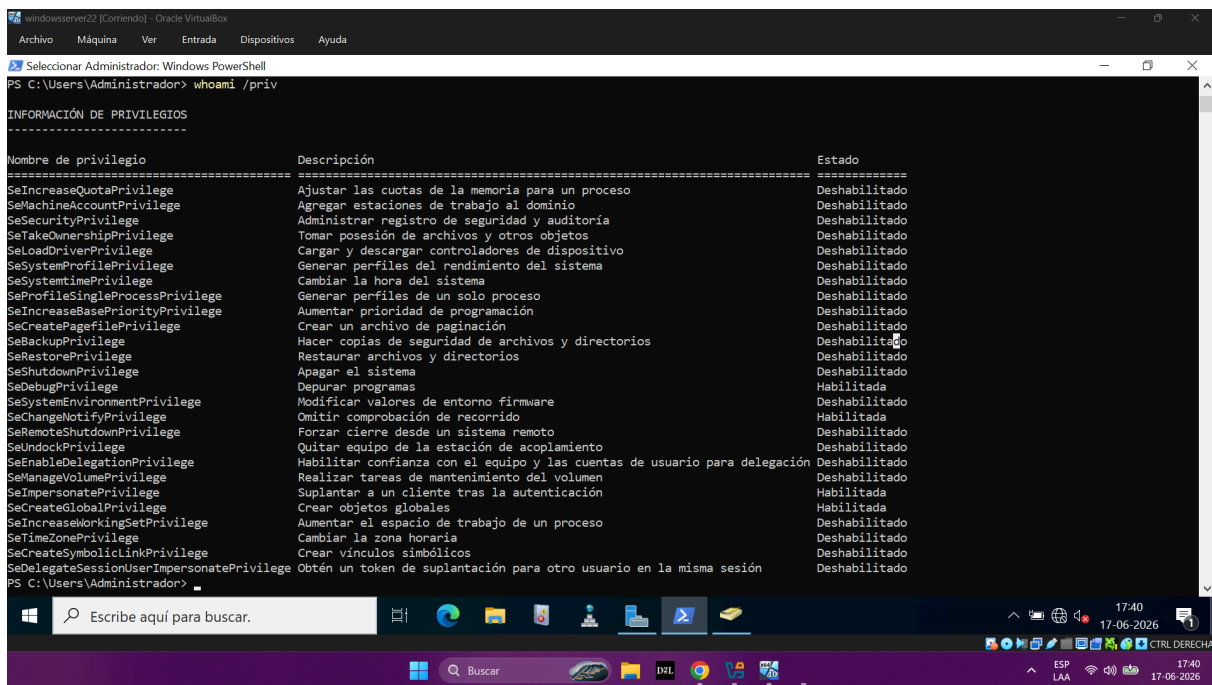
Deberías ver **hackersoc** en la lista de administradores.



PASO 4 — Simula actividad sospechosa del nuevo admin powershell

```
whoami /priv  
net user hackersoc /domain  
query user
```

Esto genera más eventos en Wazuh para analizar.



MISIÓN 2 — Detectar en Wazuh

PASO 1 — Filtra por EventID 4728

Ve a Threat Hunting → Events y busca:

`data.win.system.eventID: 4728`

EventID 4728 = Usuario agregado a grupo de seguridad global (Domain Admins)

Deberías ver algo así:

```
Quién lo hizo: Administrador
Qué hizo: Agregó hackersoc
A qué grupo: Domain Admins
Cuándo: [hora exacta]
```

Resultado del PASO 1 — Filtra por EventID 4728

Búsqueda en Wazuh: `data.win.system.eventID: 4728`

EventID 4728 = Usuario agregado a grupo de seguridad global (Domain Admins)

- **Quién lo hizo:** Administrador
- **Qué hizo:** Agregó hackersoc
- **A qué grupo:** Domain Admins
- **Cuándo:** 21:35:55 UTC - 17/06/2026

PASO 2 — Filtra por EventID 4732

```
data.win.system.eventID: 4732
```

EventID 4732 = Usuario agregado a grupo local (Administradores locales)

Resultado del PASO 2 — Filtra por EventID 4732

Búsqueda en Wazuh: `data.win.system.eventID: 4732`

EventID 4732 = Usuario agregado a grupo local (Administradores locales)

- **Quién lo hizo:** Administrador
- **Qué hizo:** Agregó hackersoc
- **A qué grupo:** Administradores (Builtin)
- **Cuándo:** 21:23:48 UTC - 17/06/2026
- **Nivel:**  12 (CRÍTICO)

PASO 3 — Filtra por EventID 4720

`data.win.system.eventID: 4720`

EventID 4720 = Cuenta de usuario nueva creada

Resultado del PASO 3 — Filtra por EventID 4720

Búsqueda en Wazuh: `data.win.system.eventID: 4720`

EventID 4720 = Cuenta de usuario nueva creada

- **Quién lo hizo:** Administrador
 - **Qué hizo:** Creó usuario `hackersoc`
 - **Cuándo:** 21:22:37 UTC - 17/06/2026
 - **Estado inicial:** Cuenta deshabilitada
 - **MITRE ATT&CK:** T1136 - Create Account
-

PASO 4 — Filtra por EventID 4672

`data.win.system.eventID: 4672`

EventID 4672 = Privilegios especiales asignados al nuevo login — este ya lo conoces del Día 1.

Resultado del PASO 4 — Filtra por EventID 4672

Búsqueda en Wazuh: `data.win.system.eventID: 4672`

EventID 4672 = Privilegios especiales asignados al nuevo login

- **Quién:** Administrador
- **Qué:** Asignación de privilegios especiales
- **Cuándo:** 21:16:06 UTC - 17/06/2026
- **Privilegios asignados:**
 - SeSecurityPrivilege
 - SeTakeOwnershipPrivilege
 - SeLoadDriverPrivilege
 - SeBackupPrivilege
 - SeRestorePrivilege
 - SeDebugPrivilege

- SeSystemEnvironmentPrivilege
 - SeEnableDelegationPrivilege
 - SelmpersonatePrivilege
 - SeDelegateSessionUserImpersonatePrivilege
 - **MITRE ATT&CK:** T1484 - Domain Policy Modification
-

PASO 5 — Busca la cadena completa del ataque

En Wazuh busca por el usuario:

hackersoc

Verás toda la cronología:

[hora 1] → EventID 4720 - Cuenta creada

[hora 2] → EventID 4728 - Agregado a Domain Admins

[hora 3] → EventID 4732 - Agregado a Administradores locales

[hora 4] → EventID 4672 - Privilegios especiales asignados

Eso se llama **cadena de ataque** y es lo que buscas en una investigación SOC real.

Resultado del PASO 5 — Busca la cadena completa del ataque

Búsqueda en Wazuh: hackersoc

EventID 4720 - Cuenta creada

- **Hora:** 21:22:37 UTC
- **Acción:** Creación de usuario hackersoc
- **Actor:** Administrador

EventID 4732 - Agregado a Administradores locales

- **Hora:** 21:23:48 UTC
- **Acción:** Agregó hackersoc al grupo Administradores (Builtin)
- **Actor:** Administrador
- **Nivel:**  12 (CRÍTICO)

EventID 4728 - Agregado a Domain Admins

- **Hora:** 21:35:55 UTC
- **Acción:** Agregó hackersoc al grupo Domain Admins

- **Actor:** Administrador

EventID 4672 - Privilegios especiales asignados

- **Hora:** 21:16:06 UTC
- **Acción:** Asignación de privilegios especiales al Administrador
- **Actor:** Administrador

Cadena de ataque identificada:

```
21:16:06 → 4672 - Privilegios especiales (Administrador)
21:22:37 → 4720 - Cuenta hackersoc CREADA
21:23:48 → 4732 - Agregado a Administradores (LOCAL) ▲
21:35:55 → 4728 - Agregado a Domain Admins
```

PASO 6 — Revisa MITRE ATT&CK

En Wazuh ve a **MITRE ATT&CK** y busca estas técnicas:

Técnica	ID	Descripción
Create Account	T1136	Creación de cuenta nueva
Valid Accounts	T1078	Uso de cuenta para privilegios
Account Manipulation	T1098	Agregar usuario a grupo admin

MISIÓN 3 — Respuesta al incidente

PASO 1 — Contén el ataque

En Windows Server elimina el usuario malicioso:

powershell

```
net user hackersoc /delete
net group "Domain Admins" hackersoc /delete /domain
```



```

PS C:\Users\Administrador> net user hackersoc /delete
Se ha completado el comando correctamente.

PS C:\Users\Administrador> net group "Domain Admins" hackersoc /delete /domain
No existe el usuario: hackersoc.

Puede obtener más ayuda con el comando NET HELPMSG 3755.

PS C:\Users\Administrador> net localgroup Administradores
Nombre de alias      Administradores
Comentario           Los administradores tienen acceso completo y sin restricciones al equipo o dominio

Miembros
-----
Administrador
Administradores de empresas
Admins. del dominio
Se ha completado el comando correctamente.

```

borre el usuario en el comando pero el grupo lo borre manualmente , donde mismo lo cree.

Verifica que se eliminó:

powershell

```

net localgroup Administradores
net group "Domain Admins" /domain

```

```

PS C:\Users\Administrador> net localgroup Administradores
Nombre de alias      Administradores
Comentario           Los administradores tienen acceso completo y sin restricciones al equipo o dominio

Miembros
-----
Administrador
Administradores de empresas
Admins. del dominio
Se ha completado el comando correctamente.

PS C:\Users\Administrador> net group "Domain Admins" /domain
No se ha encontrado el nombre de grupo.

Puede obtener más ayuda con el comando NET HELPMSG 2220.

PS C:\Users\Administrador>

```

PASO 2 — Verifica en Wazuh que aparece el evento de eliminación

Busca:

```
data.win.system.eventID: 4726
```

EventID 4726 = Cuenta eliminada — confirma que tu acción de contención quedó registrada.

Resultado del PASO 2 — Verifica en Wazuh que aparece el evento de eliminación

Búsqueda en Wazuh: `data.win.system.eventID: 4726`

EventID 4726 = Cuenta eliminada — confirma que tu acción de contención quedó registrada.

- **Quién lo hizo:** Administrador
- **Qué hizo:** Eliminó usuario `hackersoc`
- **Cuándo:** 22:06:37 UTC - 17/06/2026
- **Estado:** AUDIT_SUCCESS (Éxito)
- **MITRE ATT&CK:** T1531 - Account Access Removal

Evidencia:

"Se eliminó una cuenta de usuario. Sujeto: Administrador (SOC). Cuenta de destino: hackersoc (SOC)"

✓ **Confirmación:** La acción de contención quedó registrada correctamente en Wazuh.

REPORTE DE INCIDENTE #004

Fecha: 17 de junio de 2026

Analista: Katalina Sepulveda Lopez

Severidad: CRÍTICA ●

TIPO DE ATAQUE:

Escalada de privilegios – Privilege Escalation

CRONOLOGÍA:

Hora	EventID	Descripción
21:16:06	4672	Privilegios especiales asignados al Administrador
21:22:37	4720	Cuenta `hackersoc` creada
21:23:48	4732	`hackersoc` agregado a Administradores

```
locales |
| 21:35:55 | 4728 | `hackersoc` agregado a Domain Admins |
| 22:06:37 | 4726 | Cuenta `hackersoc` eliminada (contención) |
```

TÉCNICAS MITRE ATT&CK:

- T1136 - Create Account (Creación de cuenta)
- T1078 - Valid Accounts (Uso de cuenta válida)
- T1098 - Account Manipulation (Manipulación de cuenta)
- T1484 - Domain Policy Modification (Modificación de políticas de dominio)
- T1531 - Account Access Removal (Eliminación de cuenta)

EVIDENCIA WAZUH:

EventID	Descripción	Hora
-----	-----	-----
4720	Cuenta `hackersoc` creada	21:22:37
4732	Agregado a Administradores locales	21:23:48
4728	Agregado a Domain Admins	21:35:55
4672	Privilegios especiales asignados	21:16:06
4726	Cuenta eliminada (contención)	22:06:37

ACTIVOS AFECTADOS:

- Hostname: WIN-J36GU3SVE0C
- Sistema: Windows Server 2022 Standard Evaluation
- IP: 192.168.56.20
- Dominio: soc.local

IMPACTO:

- ● Acceso administrativo total al dominio
- ● Posible acceso a todos los equipos **del** dominio
- ● Posible creación de backdoors adicionales
- ● Capacidad de modificar políticas de seguridad
- ● Capacidad de crear/modificar/eliminar usuarios

ACCIONES DE CONTENCIÓN:

1. ✓ Cuenta `hackersoc` eliminada (`net user hackersoc /delete`)
2. ✓ Removido de Domain Admins (`net group "Domain Admins" hackersoc /delete /domain`)
3. ✓ Removido de Administradores locales (`net localgroup Administradores hackersoc /delete`)
4. ✓ Verificado en Wazuh (EventID 4726)

RECOMENDACIONES:

● Alta Prioridad

1. Auditar TODOS los grupos de administradores **del** dominio
2. Revisar si se crearon otras cuentas sospechosas
3. Cambiar contraseñas de cuentas privilegiadas

● Media Prioridad

4. Implementar alerta automática para EventID 4728, 4732 y 4720
5. Principio de mínimo privilegio en todas las cuentas
6. Configurar monitoreo de cambios en grupos privilegiados

● Baja Prioridad

7. Revisar política de contraseñas **del** dominio

8. Implementar MFA para cuentas administrativas

LECCIONES APRENDIDAS:

- La detección tardía permite al atacante crear persistencia
- EventID 4728 debe generar alerta nivel ALTO automáticamente
- Monitoreo de grupos privilegiados es crítico
- `ANONYMOUS LOGON` modificando cuentas es señal de alarma
- La cadena de ataque completa debe ser visible en el SIEM

ESTADO: CONTENIDO 

TICKET: INC-004

ESCALAMIENTO: Reportado a SOC Tier 2

FIRMA:

Katalina Sepulveda Lopez

Analista SOC

17 de junio de 2026

Tabla de EventIDs del Día 4 para tu estudio

EventID	Qué significa	Severidad SOC
4720	Cuenta nueva creada	Alta
4722	Cuenta habilitada	Media
4728	Agregado a grupo global	Alta
4732	Agregado a grupo local	Alta
4672	Privilegios especiales	Alta
4726	Cuenta eliminada	Media

EventID	Qué significa	Severidad SOC
4740	Cuenta bloqueada	Alta